F

Fabriq Labs Inc.

Fabriq Books · Cloud Accounting & Financial Operations

Corporate Headquarters
Toronto, Ontario, Canada
www.fabriqbooks.com
security@fabriqbooks.com

Information Security Policy

DOCUMENT OWNER	VERSION	EFFECTIVE DATE
Director / Security Lead	1.0	Nov 2, 2025

INTERNAL — CONTROLLED DOCUMENT

1. Policy Statement

Fabriq Labs Inc. ("Fabriq Labs," "the Company") is committed to protecting the confidentiality, integrity, and availability of information assets entrusted to us by customers, employees, partners, and third parties. This commitment extends to all information in any form—digital, physical, or verbal—and to all systems, infrastructure, and personnel involved in processing, storing, or transmitting that information.

This Information Security Policy establishes the governing framework for Fabriq Labs' information security program. It defines the principles, responsibilities, and minimum controls required to identify, assess, mitigate, and monitor information security risks relevant to our business as a provider of cloud-based accounting and financial operations software, including the Fabriq Books product.

2. Purpose and Scope

2.1 Purpose

The purpose of this policy is to:

- Establish management commitment to information security
- Define roles, responsibilities, and accountability for protecting information assets
- Provide a risk-based framework for selecting and maintaining security controls
- Ensure compliance with applicable laws, regulations, and contractual obligations
- Support the secure handling of customer financial data, including data obtained through third-party financial data providers
- Promote a culture of security awareness across the organization

2.2 Scope

This policy applies to:

- All Fabriq Labs employees, contractors, consultants, and temporary personnel
- All information systems, applications, networks, databases, and cloud services operated or managed by Fabriq Labs
- All customer data, including financial account information, transaction data, personally identifiable information (PII), and business records processed on behalf of customers
- All physical and remote work locations from which Company systems are accessed
- All third-party service providers and subprocessors with access to Company or customer data

No exclusions. This policy applies to all information assets and personnel unless a specific exception is documented and approved in writing by the Security Lead.

---

3. Security Principles

Fabriq Labs applies the following principles across all information security activities:

Defense in depth — Multiple layers of security controls protect critical assets; no single control is relied upon exclusively.

Least privilege — Access is granted only to the minimum level required to perform a job function.

Need to know — Sensitive data is accessible only to individuals with a legitimate business need.

Separation of duties — Critical functions require independent review or approval where practicable.

Secure by design — Security requirements are integrated into system design, development, and procurement.

Assume breach — Controls are designed to detect, contain, and recover from security incidents.

---

4. Governance and Risk Management

4.1 Governance Structure

Executive leadership is responsible for approving this policy, allocating resources to the information security program, and reviewing security performance at least annually. The Security Lead is responsible for day-to-day implementation, risk assessment, control oversight, and reporting to management.

4.2 Risk Management Program

Fabriq Labs maintains a formal risk management process to identify, assess, treat, and monitor information security risks. This process is operationalized through the following activities:

Information security risk assessment — Annually, and upon material change to systems, vendors, or threat landscape. Owner: Security Lead.

Risk register maintenance — Ongoing; reviewed quarterly. Owner: Security Lead.

Control effectiveness review — Annually. Owner: Security Lead.

Management review of security posture — Annually. Owner: Director / Security Lead.

Vendor security assessment — Prior to onboarding; annually for critical vendors. Owner: Security Lead.

Risk assessments consider threats to confidentiality, integrity, and availability of customer data; regulatory and contractual obligations; third-party dependencies; and the potential impact of security incidents on customers and business operations. Identified risks are assigned owners, treatment plans, and target remediation timelines. Residual risks are accepted by management where treatment is impractical or disproportionate to impact.

4.3 Security Objectives

Prevent unauthorized disclosure of customer data — Target: Zero confirmed data breaches attributable to control failure.

Maintain system availability for production services — Target: 99.9% uptime for critical production systems.

Respond to security incidents — Target: Initial triage within 4 hours; notification to affected parties per legal requirements.

Patch critical vulnerabilities — Target: Remediation within 30 days of identification (critical: 7 days).

Security awareness training — Target: 100% completion by all personnel with system access annually.

---

5. Roles and Responsibilities

Director — Approve information security policy; set risk appetite; receive annual security reports; ensure adequate resources.

Security Lead — Maintain ISMS; conduct risk assessments; oversee incident response; manage vendor security reviews; report to management.

Engineering / IT — Implement technical controls; manage access provisioning; patch systems; monitor for security events; support incident response.

All Personnel — Comply with this policy and supporting procedures; complete security training; protect credentials; report incidents promptly.

Information security is the responsibility of every individual with access to Company systems or data.

6. Data Classification and Handling

Fabriq Labs classifies information into four tiers. All personnel must handle data according to its classification.

Restricted — Highly sensitive; regulated or credential data. Examples: API secrets, encryption keys, bank access tokens, authentication credentials, government identifiers. Minimum controls: Encryption at rest and in transit; strict access controls; audit logging; no storage on personal devices.

Confidential — Sensitive business or customer data. Examples: Customer financial records, transaction data, PII, bank account metadata. Minimum controls: Encryption in transit; role-based access; logging; secure disposal.

Internal — Internal use only. Examples: Policies, internal communications, non-public business information. Minimum controls: Access limited to personnel; no public disclosure.

Public — Approved for public release. Examples: Marketing materials, published documentation. Minimum controls: Integrity protection.

Customer financial data obtained through third-party financial data providers (including Plaid) is classified as **Restricted** or **Confidential** depending on content. Such data must not be sold, rented, or disclosed to third parties except as required to deliver the Fabriq Books service to the connecting customer or as required by law.

7. Access Control

7.1 General Requirements

- Access to production systems and customer data is granted on a least-privilege, need-to-know basis
- Unique individual accounts are required; shared credentials are prohibited for production systems
- Multi-factor authentication (MFA) is required for access to production infrastructure, source code repositories, cloud consoles, and administrative dashboards
- Access is reviewed at least quarterly; access is revoked immediately upon role change or termination
- Privileged access is limited, logged, and subject to additional approval

7.2 Authentication Standards

- Passwords must meet minimum complexity requirements (12+ characters) where password-based authentication is used
- Service accounts and API credentials are documented, scoped to minimum required permissions, and rotated on a defined schedule
- Session timeouts are enforced on administrative and customer-facing applications

7.3 Customer Data Access

Access to customer financial data is limited to authorized personnel with a documented business need (e.g., support, engineering debugging with customer consent). All such access is logged and subject to audit.

---

8. Encryption and Data Protection

Data in transit — TLS 1.2 or higher for all external and inter-service communication.

Data at rest — AES-256 or equivalent for Restricted data, including API secrets and third-party financial access tokens.

Key management — Encryption keys stored separately from encrypted data; access to keys restricted to authorized personnel.

The Fabriq Books product does not store end-user bank login credentials. Financial account linking is performed through certified third-party authentication flows (e.g., Plaid Link) where credentials are handled by the provider.

---

9. Secure Development and Change Management

- Security requirements are considered during system design and architecture decisions
- Source code is managed in version control with branch protection and mandatory code review for production changes
- Dependencies are monitored for known vulnerabilities; critical vulnerabilities are remediated per the patching schedule in Section 4.3
- Secrets and credentials are not committed to source code; they are managed through environment variables or a secrets management system
- Changes to production systems follow a documented change management process including testing and rollback capability
- Multi-tenant customer data is logically isolated by organization; cross-tenant data access is prohibited by application design and access controls

10. Monitoring, Logging, and Vulnerability Management

Fabriq Labs monitors systems for unauthorized access and anomalous activity. The following controls are operationalized:

- **Logging** — Authentication events, administrative actions, and access to sensitive data are logged and retained for a minimum of 90 days
- **Log review** — Security-relevant logs are reviewed periodically and upon indication of compromise
- **Vulnerability management** — Systems are scanned for vulnerabilities; findings are tracked to remediation
- **Patching** — Operating systems, frameworks, and dependencies are kept current; emergency patches are applied for actively exploited vulnerabilities

11. Incident Response

Fabriq Labs maintains a documented Incident Response Plan that defines procedures for detecting, containing, investigating, remediating, and recovering from security incidents. The plan includes:

1. **Identification and reporting** — All personnel must report suspected security incidents to the Security Lead immediately
2. **Triage and classification** — Incidents are assessed for severity and scope within 4 hours of report
3. **Containment and eradication** — Actions taken to limit impact and remove threat
4. **Notification** — Affected customers, partners, regulators, and third-party providers (including financial data providers) are notified as required by law and contractual obligations
5. **Post-incident review** — Root cause analysis and corrective actions documented within 30 days

Security incidents involving unauthorized access to customer financial data or third-party API credentials must be reported to affected financial data providers without undue delay.

12. Third-Party and Vendor Security

Before onboarding vendors that process or store customer data, Fabriq Labs evaluates the vendor's security posture, including:

- Data handling practices and encryption standards
- Compliance certifications (e.g., SOC 2, ISO 27001) where applicable
- Incident notification obligations
- Data processing agreements and contractual security requirements

Critical vendors are reviewed annually. Vendor access to Company systems is limited, monitored, and revoked upon contract termination.

13. Physical and Environmental Security

- Company equipment is secured when unattended
- Personnel must lock workstations when leaving them unattended
- Physical access to any office or co-working facilities is controlled
- Company-owned devices used for remote work must employ full-disk encryption and screen lock

14. Acceptable Use

Personnel must use Company systems and data only for authorized business purposes. The following are prohibited:

- Sharing credentials or authentication tokens
- Storing Restricted or Confidential data on unauthorized personal devices or unapproved cloud services
- Circumventing security controls
- Installing unauthorized software on production systems
- Accessing customer data without authorization or legitimate business need

Violations may result in disciplinary action up to and including termination and legal action.

15. Training and Awareness

All personnel with access to Company systems must complete information security awareness training upon hire and annually thereafter. Training covers:

- Data classification and handling requirements
- Phishing and social engineering awareness
- Password and credential hygiene
- Incident reporting procedures
- Acceptable use obligations

16. Business Continuity

Fabriq Labs maintains procedures to ensure continuity of critical services in the event of disruption, including:

- Regular backups of production databases with tested restore capability
- Documented recovery procedures for critical systems
- Defined recovery time objectives (RTO) and recovery point objectives (RPO) for production services

17. Regulatory and Contractual Compliance

Fabriq Labs complies with applicable information security, privacy, and financial data protection requirements, including but not limited to:

- **Gramm-Leach-Bliley Act (GLBA) Safeguards Rule** — Administrative, technical, and physical safeguards for customer financial information
- **California Consumer Privacy Act (CCPA)** — Where applicable to personal information of California residents
- **Personal Information Protection and Electronic Documents Act (PIPEDA)** — Where applicable to personal information of Canadian residents
- **General Data Protection Regulation (GDPR)** — Where applicable to personal data of EU/EEA data subjects
- **Contractual obligations** with customers, partners, and financial data providers

18. Policy Compliance and Enforcement

Compliance with this policy is mandatory for all personnel and third parties with access to Company systems or data. The Security Lead monitors compliance through risk assessments, access reviews, incident tracking, and training completion records.

Non-compliance may result in disciplinary action, contract termination, or legal remedies as appropriate.

19. Policy Review and Maintenance

This policy is reviewed at least annually and updated when:

- Significant security incidents occur
- Material changes are made to systems, vendors, or business operations

- Regulatory or contractual requirements change
- Risk assessments identify new or changed risks

All revisions require approval by the Director or designated Security Lead before taking effect. Superseded versions are archived.

20. Related Documents

The following supporting procedures operationalize this policy:

Incident Response Plan — Procedures for security incident detection, response, and notification.

Access Control Procedure — User provisioning, review, and deprovisioning.

Vendor Security Assessment Procedure — Third-party risk evaluation and ongoing monitoring.

Secure Development Guidelines — Engineering security standards and code review requirements.

Data Retention and Disposal Procedure — Retention schedules and secure deletion of customer data.

Document Control

Version: 1.0

Date: Nov 2, 2025

Author: Fabriq Labs Inc.

Changes: Initial release

This document is the property of Fabriq Labs Inc.. Unauthorized distribution, reproduction, or disclosure is prohibited.